

NovaPay Six-Month PDCA Roadmap

Practical implementation plan from foundation to certification readiness

Prepared by	Bola
Organisation	NovaPay Solutions Ltd. (fictional case study)
Industry	FinTech / Digital Payments
Framework	ISO/IEC 27001:2022
Purpose	Cybersecurity GRC portfolio project

Portfolio disclaimer: NovaPay Solutions Ltd. is a fictional organisation adapted from the supplied PayNest capstone case study. No real employer, customer or production data is used.

Roadmap Objective

The six-month plan is designed to establish a working ISMS, implement priority risk treatments, collect evidence, test effectiveness and create the governance needed for an informed certification-readiness decision.

PDCA	Action	Proposed Owner	Priority	Target	Evidence / Deliverable
PLAN	Approve ISMS governance structure, roles and responsibilities.	Management / GRC	Critical	Weeks 1-2	Governance charter
PLAN	Validate business context, interested parties and ISMS scope.	GRC + Business Owners	Critical	Weeks 1-3	Approved scope and context record
PLAN	Create formal asset inventory and classification approach.	IT / GRC	High	Weeks 2-6	Asset register with owners
PLAN	Approve risk methodology and populate risk register.	GRC / Management	Critical	Weeks 2-6	Risk methodology and approved risk register
DO	Complete policy framework and supporting procedures.	GRC + Control Owners	High	Weeks 4-10	Approved policies and procedures
DO	Implement priority treatments across access, supplier, cloud, vulnerability, monitoring, development and continuity.	IT / Engineering / GRC	Critical	Months 2-4	Control evidence and action closure
DO	Establish recurring awareness training and event reporting.	GRC / HR	High	Months 2-3	Training records and reporting channel
DO	Approve SoA and risk treatment plan.	GRC / Management	Critical	Month 3	Approved SoA and treatment plan
CHECK	Define control testing, ISMS metrics and management reporting.	GRC / Security	High	Months 3-4	Metrics dashboard and test plan
CHECK	Conduct an internal ISO/IEC 27001 audit and record findings.	Independent Internal Audit	Critical	Month 5	Internal audit report
ACT	Correct audit findings and update risk/SoA documentation.	Control Owners / GRC	Critical	Months 5-6	Corrective-action evidence
ACT	Conduct management review and decide next readiness steps.	Senior Management	Critical	Month 6	Management review minutes and decisions

Readiness Phases

Timeline	Focus	Exit Evidence
0-30 Days	Foundation: context, scope, governance, policy ownership and risk criteria.	Approved scope, roles, policy roadmap and risk criteria.
30-90 Days	Risk and documentation: inventory, gaps, risk register, treatment plan, objectives and SoA.	Asset register, risk register, treatment plan, SoA and objectives.
Months 3-4	Priority control implementation.	Operational evidence across key controls.
Month 5	Check: metrics, control testing and internal audit.	Metrics, test results, internal audit report and findings log.
Month 6	Act: corrective actions, management review and readiness assessment.	Corrective actions, management review and readiness decision.
After Readiness	Certification preparation when management is satisfied the ISMS is operating effectively.	Certification plan and assessment evidence.

Important note

The roadmap does not guarantee certification within six months. It provides a practical sequence for establishing and demonstrating an operating management system. External certification should only be pursued when the organisation has sufficient evidence that the ISMS is implemented and effective.